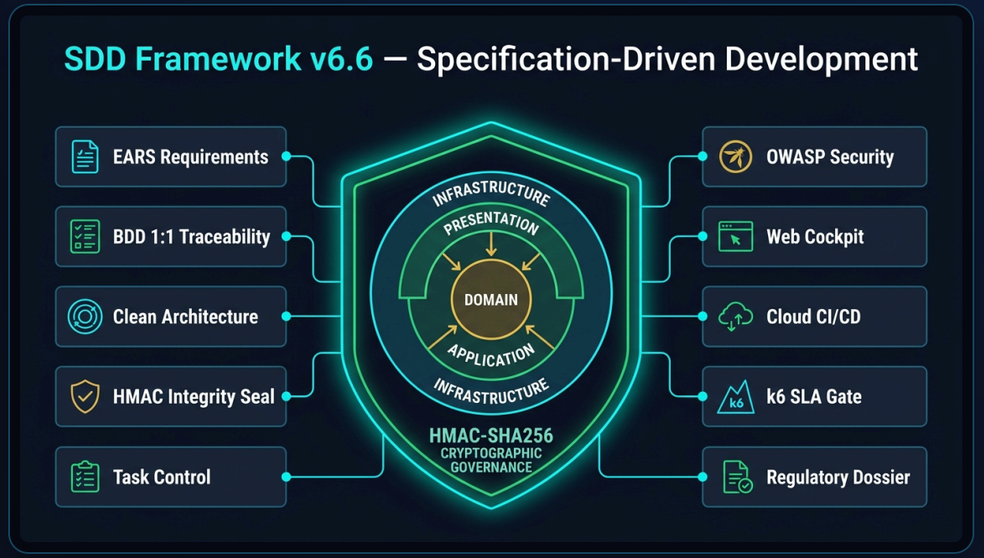
SDD Framework v6.6 — Regulatory & Compliance Hardened Edition

VERSIÓN OFICIAL 6.6

La Especificación Manda.
El Código Obedece.
La Criptografía Gobierna.

Marco de Ingeniería Determinista para el Desarrollo de Software con Agentes de Inteligencia Artificial: Sintaxis Formal **EARS**, Paridad **BDD 1:1**, **Clean Architecture Políglota**, Candado Criptográfico **HMAC-SHA256** con Identidad **HITL**, Auditor Nónuplo de **9+1 Compuertas** y Expediente de **Evidencia Técnica Auditable en PDF**.

10	9+1	20	7
PILARES SINÉRGICOS	HARD GATES	SKILLS CANÓNICAS	STACKS POLÍGLOTAS



Autor: Salvador Velasco & Antigravity (Google DeepMind Team)

El Dilema del Desarrollo con IA sin Gobernanza Determinista

6 RIESGOS CRÍTICOS

Los agentes autónomos multiplican la velocidad de escritura de código, pero sin barreras físicas y criptográficas introducen seis patologías graves en entornos corporativos y regulados:

1. Spec Drift (Deriva de Alcance)

El agente altera archivos fuera de su tarea, modifica contratos de API existentes e introduce dependencias no autorizadas para forzar que el código compile.

2. Pruebas Falsas (Fake Tests)

Generación de suites complacientes (`assert True == True`, bloques `pass` o `@skip`) que simulan 100% de cobertura sin probar la lógica real.

3. Erosión Arquitectónica

Ruptura de capas de abstracción: consultas SQL o llamadas HTTP inyectadas directamente en vistas UI y contaminación del dominio con frameworks.

4. Brechas OWASP y Secretos

Credenciales o tokens JWT hardcodeados en texto plano, concatenación insegura de SQL/comandos y paquetes con CVEs críticas.

5. Colapso de Latencia y SLA

Algoritmos cuadráticos $O(N^2)$ y consultas N+1 que aprueban tests unitarios locales pero saturan la infraestructura bajo concurrencia real.

6. Invalidez en Auditorías

Ausencia de firma humana atribuible (HITL), posibilidad de que el agente se auto-apruebe o recalcule hashes simples, y falta de expediente probatorio.

La Solución SDD v6.6: Contención Matemática y Criptográfica

SPEC-FIRST & FAIL-CLOSED

> AXIOMA RECTOR: Ninguna línea de código puede existir en src/ sin una especificación EARS + BDD + Plan sellada con HMAC-SHA256 por un humano (HITL).

1. Especificación Soberana

- Requisitos en gramática formal **EARS** (5 cláusulas libres de ambigüedad).
- Paridad biunívoca **1:1** con escenarios ejecutables Gherkin (`@AC-1.1` a `@AC-1.4`).
- Declaración explícita de lista blanca **Allowed Files** en `plan.md`.

2. Candado HMAC-SHA256 + HITL

- Firma con clave secreta de **256 bits** (`.specify/.sdd_key` o `$env:SDD_HMAC_KEY`).
- Sella conjuntamente `spec.md + scenarios.feature + plan.md`.
- Prohibida la auto-aprobación IA; registra identidad verificada (`approved_by`, `approved_at`).

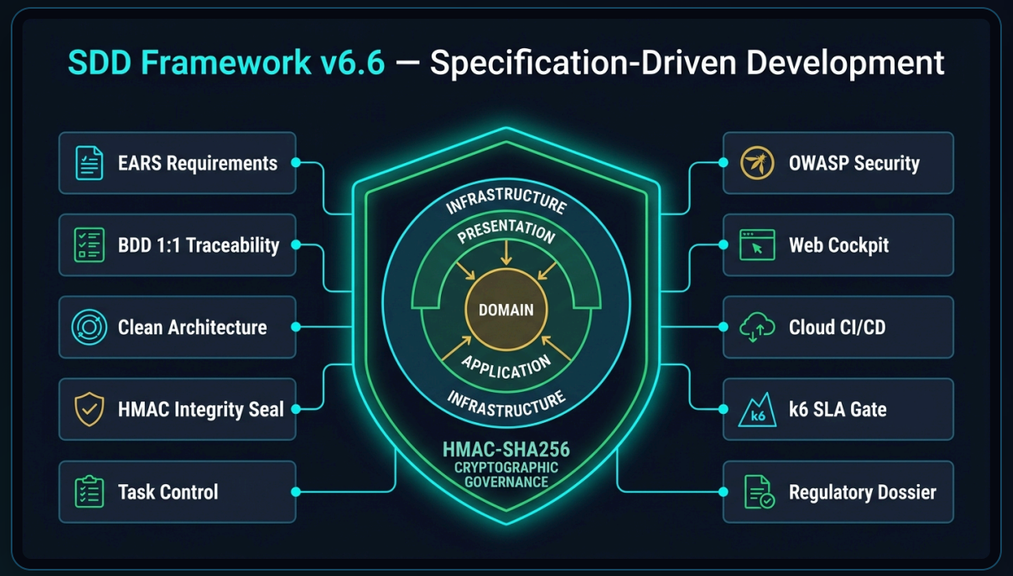
3. Ejecución Vigilada y Evidencia

- Interceptor físico **PreToolUse Fail-Closed** que bloquea escrituras ilegales en el IDE.
- **El Auditor Nónuplo** (9+1 Hard Gates) valida arquitectura, seguridad y SLA k6.
- Emisión automática de **Dossier PDF Vectorial** con evidencia técnica auditable.

Dimensión	Desarrollo con IA Convencional	SDD v6.5 (Edición Previa)	SDD v6.6 (Hardened Edition)
Integridad de Especificación	Inexistente (Prompts efímeros en chat)	SHA-256 sin llave (solo `spec.md` y `.feature`)	**HMAC-SHA256 con llave de 256 bits sobre tríada completa (+ `plan.md`)**
Gobernanza Humana (HITL)	Revisión manual post-facto	Hash sin identidad del aprobador	**Atribución obligatoria (`approved_by`, `approved_at`) + Bloqueo auto-approve**
Verificación del Propio Arnés	No aplica	Pruebas manuales	**Suite automatizada Pester 6 (6/6 Passed) + PSScriptAnalyzer (0 Errores)**

Los 10 Pilares Sinérgicos de SDD v6.6

10 PILARES DE INGENIERÍA



P1. Especificación Viva EARS

5 estructuras sintácticas formales y perímetro cerrado `Allowed Files`.

P2. BDD Riguroso 1:1

Mapeo exacto `AC-1.1..1.4` ↔ Gherkin `@AC-1.x` ↔ Pruebas reales.

P3. Clean Architecture Políglota

4 anillos concéntricos con Dominio 100% puro en 7 lenguajes.

P4. Criptografía HMAC-SHA256

Sello tridocumental con llave secreta y firma humana HITL.

P5. Control de Tareas & DAG

Grafo acíclico depends_on y orden constructivo Clean Arch.

P6. Ciberseguridad Defensiva

Modelado STRIDE, Tríada Letal, TruffleHog, SAST OWASP y CVEs.

P7. Cockpit Web & TopoSort

Dashboard HTML5 con servidor HTTP en vivo y visor DAG.

P8. Gobernanza CI/CD Cloud

Pipelines para GitHub Actions y GitLab CI con PR Summary.

P9. Rendimiento SLA (k6)

Umbrales P95 ≤ 200ms, Error 0% y transparencia `SKIPPED_LOCAL`.

P10. Evidencia Técnica PDF

Expediente vectorial Chromium para auditorías internacionales.

Candado Tridocumental HMAC-SHA256 y Atribución HITL

RFC 2104 / FIPS 198-1

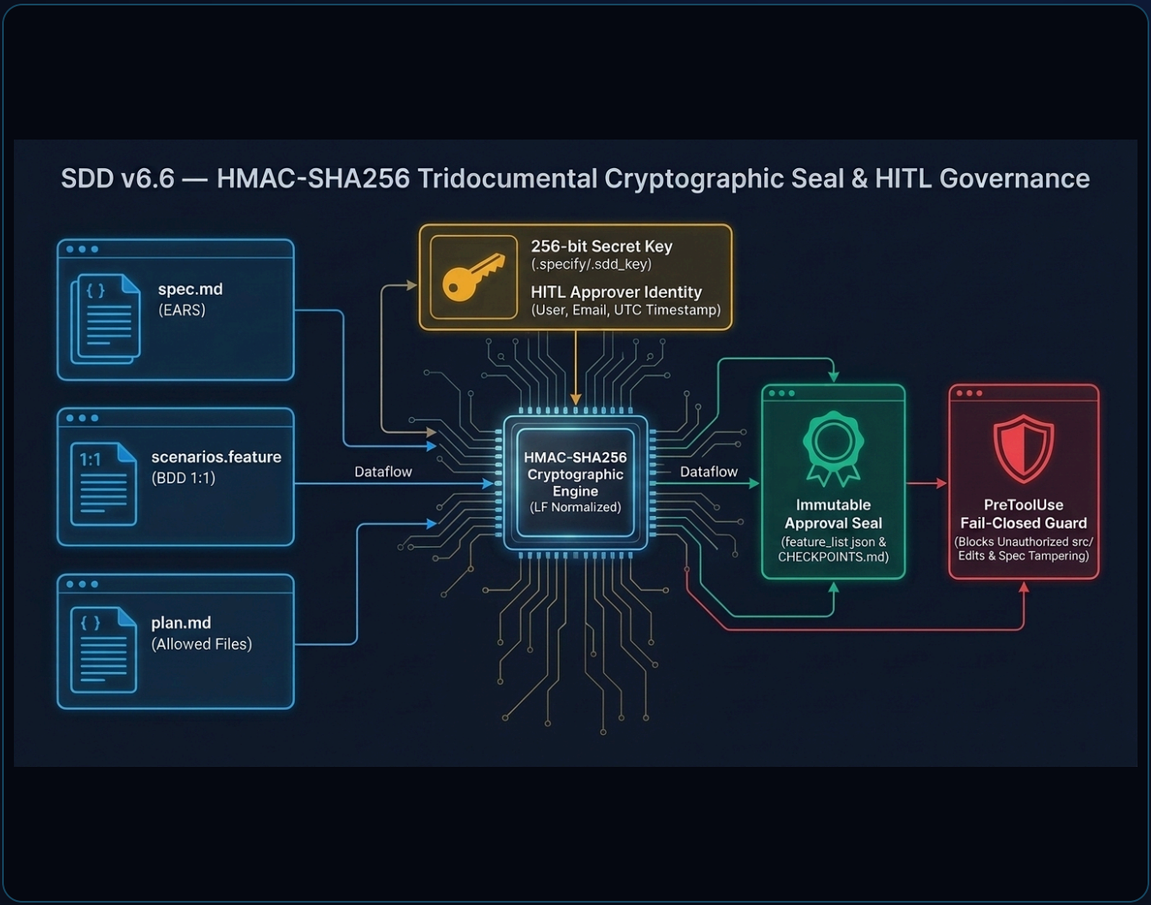
```
Seal = HMAC-SHA256_K( norm(spec.md) || "---" || norm(scenarios.feature) || "---" || norm(plan.md) )
```

Gestión Jerárquica de Llave Simétrica (256 bits)

- **Prioridad 1 (CI/CD & Cloud KMS):** Variable `$env:SDD_HMAC_KEY` inyectada desde GitHub Secrets, GitLab Masked Vars o HashiCorp Vault.
- **Prioridad 2 (Estación Local):** Llave de 32 bytes generada con CSPRNG (`RandomNumberGenerator`) en `.specify/.sdd_key`, excluida en `.gitignore` y protegida contra lectura/escritura del agente por `PreToolUse`.

Protección Total contra Spec & Plan Tampering

- Al incluir `plan.md` en el payload sellado, cualquier intento de agregar archivos no autorizados a `## Allowed Files` invalida inmediatamente el HMAC y detiene la Compuerta 0.
- Registra en `feature_list.json` y `CHECKPOINTS.md`: `approved_by` (Nombre y correo), `approved_at` (ISO-8601 UTC) y `algorithm: "HMAC-SHA256"`.



3 Hooks Deterministas Fail-Closed y 20 Skills Canónicas

.agents/hooks.json & skills/

Hook 1: SessionStart

`session-start.ps1`: Detecta automáticamente el estado del repositorio al abrir el chat. Si el proyecto es nuevo, inicia la entrevista socrática (`sdd-onboard`) de 1 pregunta por turno.

Hook 2: PreToolUse (Fail-Closed)

`pre-tool-enforce.ps1`: Intercepta `write_file` y `edit_file`. Si el destino es `src/`, recalcula en vivo el HMAC-SHA256; si no coincide con `approval_hash`, emite `decision: "deny"`.

Hook 3: PostToolUse

`post-tool-check.ps1`: Audita en segundo plano cada archivo guardado para verificar que no se introduzcan importaciones ilegales entre capas de Clean Architecture.

Dominio Operativo	Skills Canónicas Incluidas (20 Total)	Entregable Gobernado
1. Gobernanza y Descubrimiento	`#01 sdd-orchestrator`, `#02 sdd-onboard`, `#03 sdd-constitution`, `#15 sdd-reverse-spec`	`constitution.md`, backlog DAG inicial y extracción Brownfield.
2. Requisitos y Cambio Controlado	`#04 sdd-specify`, `#05 sdd-clarify`, `#14 sdd-change-spec`	`spec.md` (EARS), `scenarios.feature` (`@AC-1.1..1.4`) y RFCs.
3. Diseño UI/UX y Accesibilidad	`#06 sdd-ui-ux`, `#07 sdd-design-system`, `#08 sdd-preview-design`	`design-tokens.json` validado WCAG 2.1 AA (≥ 4.5:1) y 5 estados UI.
4. Arquitectura e Implementación TDD	`#09 sdd-plan`, `#10 sdd-tasks`, `#11 sdd-implement`	`plan.md` (Allowed Files + STRIDE), `tasks.md` y código en `src/`.
5. Seguridad, SLA, Calidad y Compliance	`#12 sdd-user-guide`, `#13 sdd-validate`, `#16 sdd-secure-coding`, `#17 sdd-dashboard`, `#18 sdd-cicd`, `#19 sdd-performance`, `#20 sdd-compliance`	Auditoría de 9+1 compuertas, Cockpit Web, pipelines CI/CD y `compliance_dossier.pdf`.

El Auditor Nónuplo: Las 9+1 Compuertas Duras Infranqueables

BLOQUEO FÍSICO EXIT 1



Gate	Compuerta Dura	Criterio de Aprobación en SDD v6.6
Gate 0	**Candado HMAC-SHA256**	HMAC en vivo de `spec + feature + plan` idéntico a `approval_hash`.
Gate 1	**Allowed Files & Anti-Drift**	0 archivos fuera de lista blanca (excluye `k6_benchmark.js` del scaffold).
Gate 2	**Paridad BDD 1:1**	Todo `AC-x.x` tiene escenario `@AC-x.x` (incluyendo `@AC-1.4`) y test.
Gate 3	**Clean Architecture**	Capa `domain` 100% pura; dependencias declaradas en manifiesto.
Gate 4	**Firma e Identidad HITL**	Estado `in_progress` con atribución `approved_by` y timestamp UTC.
Gate 5	**Anti-Fake Tests & Tareas**	0 tests vacíos/skip, 100% tareas `[x]` y corrida real de tests en verde.
Gate 6	**Guía Viva & Markdown**	`user_guide_<id>.md` completo (4 secciones) + reglas MD022/MD047.
Gate 7	**UI/UX & WCAG 2.1 AA**	0 magic hex codes, 5 estados UI y contraste calculado ≥ 4.5:1.
Gate 8	**Ciberseguridad OWASP**	0 secretos expuestos, 0 inyecciones SAST, 0 CVEs críticas y tabla STRIDE.
Gate 9	**Performance SLA (k6)**	P95 ≤ 200ms y Error 0% (o estado transparente `SKIPPED_LOCAL`).

Compatibilidad Políglota en 7 Ecosistemas Corporativos

NUEVO SOPORTE JAVA MAVEN/GRADLE

1. Domain (Núcleo)

Entidades, Value Objects y reglas corporativas puras. **Cero dependencias externas** ni anotaciones de ORM/Web.

2. Application

Casos de uso, orquestación transaccional y definición de **Puertos** (interfaces de repositorios y servicios).

3. Presentation

Controladores REST, GraphQL, vistas web/móviles o CLI. Consume `Application` sin acoplarse a `Infrastructure`.

4. Infrastructure

Adaptadores concretos: bases de datos SQL/NoSQL, clientes HTTP, colas de mensajería y proveedores cloud.

Preset Stack	Lenguaje / Plataforma	Manifiesto	Rutas Fuente / Test	Runner de Pruebas	Verificación de Tipos / Compilación
`python`	Python 3.11+ (FastAPI / Django)	`requirements.txt`	`src/` • `tests/`	`pytest`	`mypy src`
`typescript`	TypeScript / Node.js / Next / Angular	`package.json`	`src/` • `tests/`	`npm test` / `vitest`	`npx tsc --noEmit`
`csharp`	C# / .NET 8+ (ASP.NET Core)	`*.csproj`	`src/` • `tests/`	`dotnet test`	`dotnet build --no-incremental`
`golang`	Go 1.22+ Microservices	`go.mod`	`src/` • `tests/`	`go test ./...`	`go vet ./...`
`rust`	Rust (Cargo / Actix / Tokio)	`Cargo.toml`	`src/` • `tests/`	`cargo test`	`cargo check`
`flutter`	Dart / Flutter Multiplataforma	`pubspec.yaml`	`lib/` • `test/`	`flutter test`	`flutter analyze`
`java-maven`	**Java 21+ (Spring Boot 3 / Maven) [NUEVO v6.6]**	`pom.xml`	`src/main/java` • `src/test/java`	`mvn test`	`mvn compile -q`

Ciberseguridad STRIDE/OWASP y Sinceramiento de SLAs k6

ADUANAS 8 Y 9

Aduana 8: Ciberseguridad Defensiva (`verify-security.ps1`)

- **Modelado STRIDE Obligatorio:** Cada `plan.md` documenta mitigaciones contra *Spoofing, Tampering, Repudiation, Information Disclosure, DoS* y *Elevation of Privilege*.
- **Detección de la Tríada Letal:** Alerta ante módulos que combinan *Datos Sensibles + Entrada Externa No Confiable + Salida a Red*.
- **Escaneo de Secretos y SAST:** Bloquea llaves privadas, JWTs, concatenación SQL, `eval()`, Path Traversal y dependencias con CVEs altas/críticas.

Aduana 9: Rendimiento SLA Dual Honesto (`verify-performance.ps1`)

- **Contrato Declarativo k6:** Valida en `tests/performance/k6_benchmark.js` que la latencia cumpla **P95 ≤ 200 ms**, **P99 ≤ 500 ms** y **Error Rate == 0.0%**.
- **Modo Activo (CI/CD o Host con k6):** Ejecuta carga concurrente real (10 VUs) y emite `status: "CERTIFIED"`, `sla_certified: true`.
- **Sinceramiento Local v6.6 (Host sin k6):** Emite advertencia `[WARN]`, registra `status: "SKIPPED_LOCAL"` y `sla_certified: false` sin falsear métricas.

≤ 200 ms
UMBRAL CONTRACTUAL P(95)

0.0%
TASA MÁXIMA DE ERROR HTTP

0 CVEs
VULNERABILIDADES CRÍTICAS PERMITIDAS

Cockpit Web en Vivo y Expediente de Evidencia Técnica en PDF

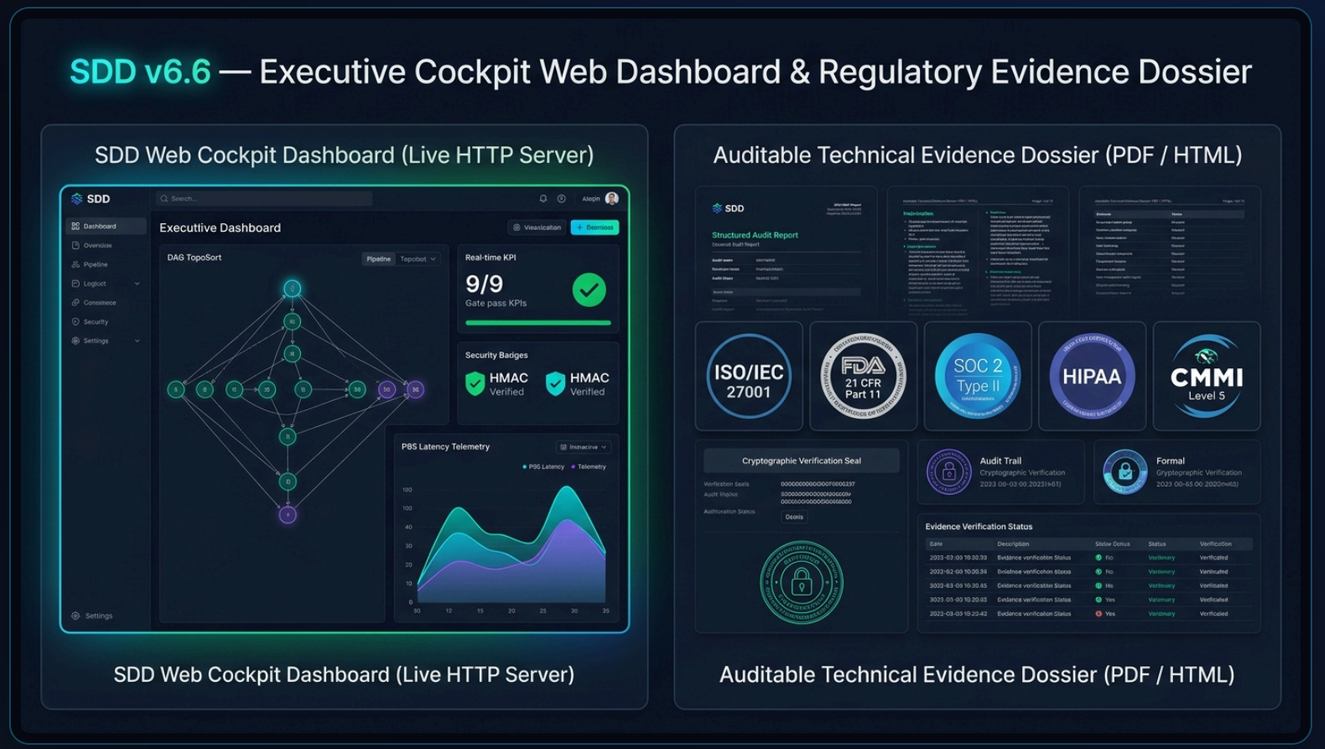
CHROMIUM HEADLESS VECTOR PDF

Cockpit Web Dashboard (`dashboard.ps1 -Live`)

- Visualización interactiva del **Grafo DAG** con algoritmo de ordenamiento topológico (*TopoSort*).
- Servidor HTTP embebido en PowerShell (`http://localhost:8080`) con recarga automática.
- Monitoreo de sellos HMAC, aprobadores HITL y estado de las 9 compuertas.

Expediente de Evidencia Auditable (`export-compliance.ps1`)

- Compilación sin dependencias externas mediante **Chromium Headless** (Edge / Chrome).
- Genera `progress/compliance_dossier.pdf` (A4 vectorial) y `.html`.
- Consolida especificaciones EARS, paridad BDD, firmas HMAC-SHA256, bitácora HITL y reportes SAST/k6.



Mapeo de Evidencia Técnica Auditable ante Normas Internacionales

SOPORTE DE AUDITORÍA

SDD v6.6 adopta un lenguaje regulatorio riguroso: no suplanta a las entidades acreditadoras, sino que provee **Evidencia Técnica Determinista, Trazable e Inmutable** que satisface los controles de ingeniería de software de los principales estándares:

Estándar / Regulación	Cláusula o Control	Exigencia Normativa	Evidencia Técnica Aportada por SDD v6.6
ISO/IEC 27001:2022	Anexo A.8.25, A.8.28, A.8.32	Ciclo de vida de desarrollo seguro, codificación segura y control formal de cambios.	Aislamiento Clean Architecture (Gate 3), SAST/Secretos (Gate 8) y sello HMAC-SHA256 tridocumental (Gate 0/1).
FDA 21 CFR Part 11	Sec. 11.10, 11.50, 11.70	Audit trails con estampa de tiempo y manifestación de firma electrónica vinculada al registro.	Metadatos inmutables `approved_by` (Nombre/Email), `approved_at` (UTC), `approval_reason` y enlace HMAC de 256 bits.
SOC 2 Type II (AICPA)	CC6.8, CC7.1, CC8.1	Prevención de cambios o código no autorizado y pruebas previas al despliegue.	Interceptor físico `PreToolUse` Fail-Closed + bloqueo de `Allowed Files` + paridad BDD 1:1.
HIPAA Security Rule	45 CFR § 164.312(b), (c)(1)	Controles de auditoría y mecanismos electrónicos de corroboración de integridad.	Verificación criptográfica continua en `init.ps1`, `pre-tool-enforce.ps1` y `spec-gate.ps1`.
ISO/IEC 25010 & CMMI L5	Calidad de Producto / QPM & CAR	Mantenibilidad modular, eficiencia de desempeño y gestión cuantitativa estadística.	Telemetría de percentiles P95/P99 en k6 y suite de regresión de gobernanza en Pester 6.

Las 12 Recomendaciones Implementadas en v6.6 + Suite Pester 6

6/6 TESTS PASSED • 0 ERRORES AST

ID	Nivel	Mejora Implementada en SDD v6.6	Verificación Automatizada (`tests/v66-governance.Tests.ps1`)
P0.1	P0 Crítico	Candado **HMAC-SHA256** real con llave simétrica en `.specify/.sdd_key` o `$env:SDD_HMAC_KEY`.	PASS Verifica algoritmo HMAC-SHA256 y llave de 256 bits.
P0.2	P0 Crítico	Inclusión de `plan.md` (`Allowed Files`) en el cómputo del sello criptográfico.	PASS Detecta adulteración en `plan.md` y bloquea Gate 0.
P0.3	P0 Crítico	Paridad BDD 1:1 completa de fábrica incluyendo escenario `@AC-1.4` en plantillas.	PASS Confirma presencia de `@AC-1.4` al crear feature.
P0.4	P0 Crítico	Exclusión de `tests/performance/k6_benchmark.js` de falsos positivos en Gate 1.	PASS Cero falsos positivos de Spec Drift en scaffold.
P0.5	P0 Crítico	Secuencia estricta de Clean Architecture en `tasks.template.md` (Domain → API).	PASS Inspección estructural de plantillas generadas.
P1.1	P1 Alto	Trazabilidad de identidad HITL (`approved_by`, `approved_at`) y bloqueo de auto-aprobación.	PASS Valida registro de identidad Git/OS y fecha ISO-8601.
P1.2	P1 Alto	Soporte nativo para stack **Java (Maven/Gradle)** en `sdd.ps1 set-stack`.	PASS Configura `pom.xml`, `mvn test` y `src/main/java`.
P1.3	P1 Alto	Sinceramiento de Gate 9: estado `SKIPPED_LOCAL` con `WARN` cuando k6 no está instalado.	PASS Valida JSON `status == "SKIPPED_LOCAL"` sin k6.
P1.4	P1 Alto	Refinamiento de vocabulario regulatorio a **"Evidencia Técnica Auditable"**.	PASS Verificado en `export-compliance.ps1` y Libro Blanco.
P2.1–P2.2	P2 Medio	Archivo de 70 scripts legacy en `archive/` + banderas `-DestinationPath` y `-NoAutoLaunch`.	PASS PSScriptAnalyzer: 0 errores; PyCompile: 0 errores.

Impacto Estratégico de Adoptar SDD v6.6 en la Organización

BENEFICIOS MEDIBLES

0%
SPEC DRIFT O ALTERACIÓN NO DETECTADA

100%
PARIDAD BIDIRECCIONAL REQUISITOS ↔ TESTS

-85%
TIEMPO DE PREPARACIÓN DE AUDITORÍAS

3x
VELOCIDAD DE ENTREGA CON CALIDAD CERTIFICADA

Para Dirección de Ingeniería y Arquitectura (CTO / VP Eng)

- Estandarización homogénea de repositorios en 7 lenguajes bajo Clean Architecture.
- Eliminación de deuda técnica invisible generada por asistentes de IA sin supervisión.
- Visibilidad en tiempo real del avance del backlog y cuellos de botella en el Cockpit DAG.

Para Seguridad de la Información y Auditoría (CISO / Compliance)

- Cadena de custodia criptográfica HMAC-SHA256 con atribución nominal de cada aprobación humana.
- Prevención proactiva de fugas de credenciales, inyecciones OWASP y dependencias vulnerables antes del commit.
- Emisión instantánea de expedientes PDF vectoriales listos para revisión de auditores externos.

Adopción en 3 Pasos y Entregables Oficiales de la Versión 6.6

LISTO PARA PRODUCCIÓN

Paso 1: Inicializar Scaffold v6.6

Ejecutar el generador en PowerShell o Python (modo interactivo o desatendido):

```
.\setup-sdd-project-v66.ps1 \
  -ProjectName "MiSistema" \
  -DestinationPath "D:\Apps" \
  -NoAutoLaunch
```

Paso 2: Configurar Stack y Sellar Spec

Seleccionar el perfil políglota, redactar la tríada EARS/BDD/Plan y firmar con HITL:

```
.\harness\sdd.ps1 -Action set-stack -Stack java-maven
.\harness\sdd.ps1 -Action create -FeatureId FEAT-001
.\harness\sdd.ps1 -Action approve -FeatureId FEAT-001
```

Paso 3: Auditar 9 Gates y Emitir PDF

Validar seguridad, rendimiento k6, cerrar funcionalidad y exportar el dossier regulatorio:

```
.\harness\sdd.ps1 -Action complete -FeatureId FEAT-001
.\harness\sdd.ps1 -Action export-compliance -Format all
.\harness\sdd.ps1 -Action dashboard -Live
```

Paquete Completo de Entregables en el Repositorio (`D:\.antigravity\sdd-projects`)

1. Generadores Multiplataforma: `setup-sdd-project-v66.ps1` y `setup-sdd-project-v66.py` | **2. Libro Blanco Maestro:** `DOCUMENTO_MAESTRO_PROYECTO_SDD_V66.md / .html / .pdf` | **3. Guía Operativa:** `GUIA_MAESTRA_SETUP_SDD_V66.md / .html / .pdf` | **4. Suite de Gobernanza Pester 6:** `tests/v66-governance.Tests.ps1`